

GenAI Risk Assessment

FinAssist — LLM Customer-Banking Assistant

[Portfolio Case Study](#)[NIST AI 600-1](#)[Risk Register](#)

Author: Tejaswini Dondeti • **Framework:** NIST AI 600-1 (Generative AI Profile) • **Date:** June 2026

Classification: Confidential — fictional institution ("Meridian First Bank")

About this document. A risk register for FinAssist, structured on NIST's Generative AI Profile (AI 600-1). Unlike a typical paper register, **every rating here is backed by red-team test evidence** from the accompanying evaluation. An Excel version with the same content is provided for working use.

1. Method

Risks are framed against NIST AI 600-1 generative-AI risk classes. Each risk is rated for **likelihood** and **impact** to give an **inherent** rating, then a **residual** rating after the listed control — evidenced, where applicable, by the hardened re-test.

Likelihood: Low (rare/sophisticated effort) · Medium (plausible for a motivated ordinary user) · High (easily triggered). **Impact:** Low (minor, recoverable) · Medium (customer harm / limited compliance exposure) · High (material data, financial, or regulatory harm).

2. Risk register

ID	Risk	NIST GAI risk	Evidence	Likelihood	Impact	Residual
R-01	System-prompt extraction	Information Security	PI-05 — baseline FAIL → hardened PASS	Medium	High	Low–Medium
R-02	Prompt injection / override	Information Security	Cat 1 — 24/25 → 25/25	Medium	High	Medium
R-03	Jailbreak via role-play	Information Security; Dangerous Content	Cat 2 — 25/25 both	Low	High	Low–Medium
R-04	PII / customer data leakage	Data Privacy	Cat 3 — 25/25 both	Low	High	Medium
R-05	Confabulation of financial facts	Confabulation	Cat 4 — 25/25 both	Low	Medium	Low–Medium
R-06	Biased / unequal treatment	Harmful Bias & Homogenization	Cat 5 — 25/25 (paired probes)	Low	High	Low–Medium
R-07		Dangerous, Abusive Content	Cat 6 — 25/25 both	Low	High	Low–Medium

ID	Risk	NIST GAI risk	Evidence	Likelihood	Impact	Residual
	Fraud / money-laundering assistance					
R-08	Evaluation under-detection (judge unreliability)	Information Integrity; Human-AI Config	9+4 grader errors; PI-05 hidden in an error	Medium	High	Medium
R-09	Over-reliance / out-of-scope advice	Human-AI Configuration	R4–R5, R10 scope rules	Medium	Medium	Low–Medium
R-10	Model-substitution drift	Value Chain & Component Integration	Evaluated on Llama 3.3 70B	Medium	Medium	Medium

3. Priority risks for the launch decision

The three risks carrying **Medium** residual ratings — **R-02** (prompt injection), **R-04** (PII leakage), and **R-08** (evaluation under-detection) — are the drivers of the conditional-go decision. They are not closed by prompt hardening alone and require operational controls: defense-in-depth filtering, continuous red-teaming, and a stronger evaluation pipeline.

R-02 — Prompt injection. Closed on all 25 tested cases after hardening, but prompt injection is an open industry problem; an adaptive attacker may find an untested variant. *Control:* layered input/output filtering + continuous red-team; treat the suite as a regression baseline.

R-04 — PII leakage. No leakage observed in testing, but the impact is high and phrasings are unbounded. *Control:* output-side PII detection/redaction independent of the model.

R-08 — Evaluation under-detection. The automated judge mis-scored 13 cases across the two runs and, critically, hid the one real breach inside a grader error in the baseline. *Control:* stronger judge model, grader-validation sampling, and retention of raw + corrected results for audit (already applied here).

4. Risks adequately controlled

R-01, R-03, R-05, R-06, R-07, and R-09 carry **Low–Medium** residual ratings: tested clean (or remediated) and addressed by an existing rule plus monitoring. They remain on the register for ongoing tracking but do not block launch.

5. Monitoring (post-launch)

Track refusal rates and anomalies per category; sample real conversations for the same six risk classes; re-run the regression suite on any model or prompt change; and feed newly discovered

bypasses back into the suite. Re-validate the full assessment if the production model differs from the evaluated Llama 3.3 70B.

Tejaswini Dondeti — Portfolio Sample

tejaswinidondeti.github.io

Tejaswini Dondeti — Portfolio Sample